

INFORME VISUAL DE AUDITORÍA DE SEGURIDAD

CONTRATO INTELIGENTE EVALUADO: HIDDENTREASURY | METODOLOGÍA OWASP 2026

Proyecto: HiddenTreasury (Bóveda de Custodia Contable)

Compilador: Solidity ^0.8.20

Auditoría: Protocolo Automatizado Senior

Dictamen Final: **RECHAZADO (CRÍTICO)**

1. DIAGNÓSTICO DE RIESGO Y MÉTRICAS DE EJECUCIÓN

RIESGO GENERAL DE SEGURIDAD: 85/100 (NIVEL CRÍTICO)

480s	3	100%	1.0	1 ■ 1 ■ 1 ■
Tiempo Análisis	Fallas Detectadas	Cobertura Lógica	F1-Score Mapeado	Criticidad (C / A / M)

2. ARQUITECTURA DE FLUJO Y VECTORES DE ATAQUE

Lógica Operativa: Administrar depósitos contables de Ether de usuarios mediante mapeos internos, incorporando funciones para derivar capital líquido a tesorerías externas.

- **Insolencia Provocada por Descalce Contable (SC07):** La función `transferToTreasury()` extrae Ether directamente del contrato sin restar ni actualizar los balances del mapping de usuarios, rompiendo la paridad y provocando quiebras de liquidez.
- **Inflación Arbitraria de Estado en Receive (SC04):** La función nativa `receive()` asigna de forma directa balances utilizando `msg.sender`. El envío forzado de Ether mediante `selfdestruct` rompe las matemáticas internas de verificación del contrato.

3. MATRIZ DE DETECCIONES EVALUADAS (OWASP Smart Contract Top 10)

Riesgo / Vector	Descripción Breve e Impacto Económico	Severidad	SWC ID	Categoría OWASP
Centralized Asset Extraction	Extracción unilateral de Ether líquido sin reflejar la baja contable en los saldos reales.	CRITICAL	SWC-105	SC07: Bad Business Logic
State Inflation via Receive	Incremento defectuoso de saldos contables expone el pool a descalses de balance.	HIGH	N/A	SC04: Resource Management
Zero Address Missing Check	Falta de validación preventivas al reasignar el control del dueño (owner).	MEDIUM	SWC-123	SC01: Broken Access Control

4. EVALUACIÓN Y VALIDACIÓN DEL MODELO MATRICIAL

Matriz de Confusión (Detecciones)	Métricas de Rendimiento
• Verdaderos Positivos (TP): 3 • Falsos Positivos (FP): 0	• Precisión del Modelo: 1.0 (100%) • Exhaustividad (Recall): 1.0 (100%)
• Falsos Negativos (FN): 0	• F1-Score Combinado: 1.0